

LEITFADEN FÜR DATENSCHUTZBEAUFTRAGTE



Microsoft Copilot im Zahlungsinstitut

Datenschutz unter BaFin-Aufsicht

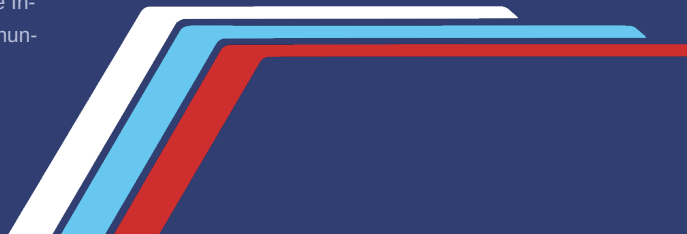
Was DSGVO, DORA und ZAG verlangen, wenn ein Zahlungsinstitut Copilot, Copilot Chat und Agenten einführt – und welche Einstellungen, Verträge und Nachweise der Datenschutzbeauftragte prüfen sollte.

Zielgruppe: Datenschutzbeauftragte in BaFin-beaufsichtigten Zahlungsinstituten (ZAG) · Informationssicherheit, IKT-Risikomanagement, Auslagerungsmanagement, Compliance und Geldwäscheprävention als Mitleser.



Bereitgestellt von der Copilotenschule.

Die Copilotenschule ist spezialisiert auf die Einführung und Weiterqualifizierung im Umfeld des Microsoft Copiloten. Wir bieten keinen Bauchladen an KI-Tools an, sondern konzentrieren uns auf das, was in Microsoft 365 tatsächlich ankommt: Schulungen, Workshops und Beratung für Geschäftsführung, Fachbereiche, Administratoren, Betriebsräte und Datenschutzbeauftragte – auch dort, wo die Aufsicht mitliest. Alle Inhalte werden regelmäßig gegen die Microsoft-Dokumentation und die Veröffentlichungen der Aufsichtsbehörden geprüft.



**INHALT**

Inhaltsverzeichnis

Wichtiger Hinweis / Haftungsausschluss.....	3
Checkliste für Datenschutzbeauftragte	4
Grundlagen: zwei Rechtsrahmen, eine Einführung.....	5
So lesen Sie die Kapitel.....	6
 TEIL A · AUFSICHTSRECHT VERSTEHEN	
1 · Wie Copilot mit Daten umgeht.....	7
2 · DORA: Copilot ist IKT-Asset und IKT-Dienstleistung.....	8
3 · ZAIT aufgehoben, ZAG-MaRisk und § 26 ZAG bleiben	9
4 · Die Einstufungsfrage: kritische oder wichtige Funktion?	10
5 · Was die BaFin-Orientierungshilfe zu KI erwartet.....	11
 TEIL B · DATENSCHUTZ PRÜFEN	
6 · Rollen, Zwecke und Rechtsgrundlagen	12
7 · EU Data Boundary: die Ausnahmen kennen	14
8 · Oversharing ist im Zahlungsinstitut ein Vertraulichkeitsproblem	16
9 · Protokollierung, Aufbewahrung, Löschung	17
10 · Datenschutz-Folgenabschätzung	18
 TEIL C · VERTRÄGE, VORFÄLLE, KI-VERORDNUNG	
11 · Verträge: DPA plus DORA-Klauseln	19
12 · Vorfälle: zwei Meldewege, zwei Uhren	20
13 · KI-Verordnung, KI-MIG und Schulungspflicht.....	21
14 · Agenten und Copilot Studio: eigene Prüfspur.....	22
 TEIL D · HANDELN	
15 · Änderungen im Blick behalten.....	23
16 · Zuständigkeiten und Fragen, die der DSB stellen sollte.....	24
Schulung: Copilot im regulierten Institut	25
Quellen & Rechtsgrundlagen.....	26



RECHTLICHER HINWEIS

Wichtiger Hinweis / Haftungsausschluss

Die Recherche zu diesem Leitfaden wurde gründlich und nach bestem Wissen und Gewissen durchgeführt. Die Aussagen wurden gegen die zitierten Primärquellen geprüft: Rechtstexte der EU und des Bundes, Veröffentlichungen von BaFin, EBA und ESAs, Papiere der Datenschutzkonferenz und die offizielle Microsoft-Dokumentation (Stand der Prüfung: Oktober 2026). Dennoch wird keine Garantie für Richtigkeit, Vollständigkeit oder Aktualität übernommen. Microsoft ändert Produktverhalten, Voreinstellungen und Vertragsdokumente laufend, und auch der aufsichtsrechtliche Rahmen ist in Bewegung.

Dieser Leitfaden ersetzt weder Rechtsberatung noch die eigene aufsichtsrechtliche Bewertung des Instituts oder eine tenant-spezifische Datenschutz- und Sicherheitsprüfung. Er richtet sich an Zahlungsinstitute mit Erlaubnis nach § 10 ZAG. Für E-Geld-Institute gilt vieles entsprechend, die Einzelheiten sind gesondert zu prüfen.

Wo eine Aussage nicht wörtlich in einer Quelle steht, sondern eine eigene Einordnung der Copilotenschule ist, ist sie als **Ein-schätzung** gekennzeichnet. Microsoft benennt die Produkte derzeit um: Microsoft 365 Copilot heißt laut Microsoft inzwischen „Microsoft Copilot“, Microsoft 365 Copilot Chat „Microsoft Copilot Chat“. Dieser Leitfaden verwendet die eingeführten Namen.

Der Kerngedanke in einem Satz

„Im Zahlungsinstitut ist Copilot zweierlei: eine Verarbeitung personenbezogener Daten nach DSGVO und ein IKT-Asset mit IKT-Dienstleister nach DORA.“

Beide Sichten prüfen dieselbe Technik, aber mit unterschiedlichen Fragen, Fristen und Verantwortlichen. Der Datenschutzbeauftragte verantwortet DORA nicht. Er muss aber wissen, wo die Aufsicht dieselben Fragen stellt wie er, damit Nachweise einmal entstehen und doppelt tragen.

Die meisten Copilot-Leitfäden sind für Unternehmen ohne Finanzaufsicht geschrieben. Sie behandeln Datenschutz, Berechtigungen und Betriebsrat. In einem Zahlungsinstitut kommt eine zweite Ebene hinzu: Seit dem 17. Januar 2025 gilt der Digital Operational Resilience Act (DORA), die BaFin hat die ZAIT aufgehoben, und im Dezember 2025 hat sie eine Orientierungshilfe zu IKT-Risiken beim Einsatz von KI veröffentlicht, die einen LLM-Assistenten für Texte, E-Mails und Präsentationen als Fallstudie durchspielt. Das ist faktisch das Copilot-Szenario.

Dieser Leitfaden ordnet beide Ebenen. Er erklärt, was im Tenant tatsächlich mit Daten passiert, welche Voreinstellungen Daten aus der EU Data Boundary führen können, welche Register, Verträge und Meldewege die Aufsicht erwartet und wo der DSB seine Prüfung mit IKT-Risikomanagement, Auslagerungsmanagement und Geldwäscheprävention verzahnen sollte. Die technische Umsetzung im Admin-Portal beschreibt der begleitende Admin-Leitfaden „Grounding sicher gestalten“, die Mitbestimmung der Betriebsrats-Leitfaden.



ZUM ABHAKEN

Checkliste für Datenschutzbeauftragte

Die Kurzfassung des Leitfadens. Die Verweise (K1–K16) führen zum jeweiligen Kapitel. Reihenfolge und Dokumentation sind wichtiger als Tempo: Was hier fehlt, fällt spätestens in der Jahresabschlussprüfung, einer Sonderprüfung oder bei der Datenschutzaufsicht auf.

PHASE 1 · VOR DEM PILOT

- ☐ Einsatzzwecke und Produktumfang schriftlich festgelegt: Microsoft 365 Copilot, Copilot Chat, Agenten, Copilot Studio – jeweils mit erlaubten und ausgeschlossenen Anwendungsfällen. → K6
- ☐ Mit IKT-Risikomanagement und Auslagerungsbeauftragtem geklärt, ob Copilot eine kritische oder wichtige Funktion unterstützt. Ergebnis und Begründung dokumentiert. → K4
- ☐ Vertragsstack geprüft: aktuelle DPA-Fassung, Product Terms, DORA-Addendum bzw. Financial Services Amendment, Abgleich mit Art. 30 DORA. → K11
- ☐ Eintrag im DORA-Informationsregister veranlasst; Einordnung nach § 26 ZAG (Auslagerungsregister, gegebenenfalls Anzeige) mit dem Auslagerungsmanagement abgestimmt. → K3
- ☐ Datenschutz-Folgenabschätzung begonnen, mit gemeinsamer Risikobasis zur IKT-Risikobewertung nach Art. 28 Abs. 4 DORA. → K10

PHASE 2 · VOR DEM BREITEN ROLLOUT

- ☐ Die Einstellungen zum Verarbeitungsort bewusst entschieden und dokumentiert: Web-Suche, Flex Routing, Anthropic (zwei Schalter), OpenAI als Unterauftragsverarbeiter und – vor dem 14.12.2026 – die Speicherung in Deutschland. → K7
- ☐ Oversharing-Assessment liegt vor; Bereiche mit KYC-, GwG-, Betrugs- und Personaldaten sind abgesichert (Restricted Content Discovery, Sensitivity Labels, DLP für Copilot). → K8
- ☐ Aufbewahrung und Löschung für Copilot-Interaktionen und Audit-Daten festgelegt – über eigene Purview-Richtlinien statt Standardwerte. → K9
- ☐ Regeln für Agenten: Data Policies im Power Platform Admin Center, Freigabeprozess mit Steckbrief, Verantwortlicher je Agent. → K14
- ☐ Rechtsgrundlage für Beschäftigendaten dokumentiert; Mitbestimmung nach § 87 Abs. 1 Nr. 6 BetrVG geklärt, Betriebsvereinbarung abgestimmt. → K6

PHASE 3 · LAUFENDER BETRIEB

- ☐ Vorfallprozess ergänzt: KI-Vorfälle kennzeichnen, DORA-Klassifizierung und DSGVO-Risikobewertung parallel und mit gemeinsamem Triage-Bogen. → K12
- ☐ Schulung von Leitungsorgan und Beschäftigten nachweisbar (Art. 5 Abs. 4 und Art. 13 Abs. 6 DORA, Art. 4 KI-VO, Art. 39 DSGVO). → K13
- ☐ Änderungsmonitoring eingerichtet: Message Center, Unterauftragsverarbeiterliste und DPA-Fassungen mindestens quartalsweise mit Auswirkung auf DSFA und Register prüfen. → K15
- ☐ Verzeichnis der Verarbeitungstätigkeiten, Datenschutzhinweise für Beschäftigte und DSFA bei jeder neuen Copilot-Funktion fortgeschrieben. → K10



Zwei Rechtsrahmen, eine Einführung

Warum der Datenschutzbeauftragte im Zahlungsinstitut mehr Normen kennen muss als im Industrieunternehmen.

In einem nicht regulierten Unternehmen reicht für Copilot im Kern die Kombination aus DSGVO, BDSG und Betriebsverfassungsrecht. Ein Zahlungsinstitut mit Erlaubnis nach § 10 ZAG unterliegt zusätzlich der laufenden Aufsicht durch BaFin und Bundesbank. Die Aufsicht interessiert sich nicht für Datenschutz als solchen, wohl aber für Vertraulichkeit, Integrität und Verfügbarkeit von Daten, für Drittanbierterrisiken und für eine nachvollziehbare Dokumentation. An diesen Stellen überschneiden sich die Rahmen, und genau dort lohnt die Zusammenarbeit. Die NIS2-Umsetzung im neuen BSI-Gesetz (in Kraft seit 6. Dezember 2025) kommt dagegen nicht hinzu: Finanzunternehmen, die DORA unterliegen, sind nach § 28 Abs. 6 BSIG von den Risikomanagement-, Melde- und Geschäftsleitungspflichten der §§ 30 bis 39 BSIG ausgenommen.

Rahmen	Kernnormen	Was für Copilot daraus folgt	Federführung im Institut
DSGVO / BDSG	Art. 5, 6, 9, 28, 30, 32–35 DSGVO	Zweck und Rechtsgrundlage, Auftragsverarbeitung, TOM, DSFA, Meldung von Datenschutzverletzungen	Verantwortlicher; DSB berät und überwacht
DORA mit RTS/ITS	Art. 5–15, 17–19, 28–30 VO (EU) 2022/2554; DelVO 2024/1773, 2024/1774, 2025/532	IKT-Risikomanagement, IKT-Drittparteienrisiko, Pflichtinhalte von Verträgen, Informationsregister, Vorfalldmeldung	Leitungsorgan; IKT-Risikokontrollfunktion
ZAG / ZAG-MaRisk	§§ 26, 27, 59 ZAG; Rundschreiben 07/2024 (BA)	Auslagerung und Auslagerungsregister, ordnungsgemäße Geschäftsorganisation, Dokumentation, Datenschutz im Zahlungsverkehr	Geschäftsleitung; Auslagerungsmanagement
BaFin-Verlautbarungen	Orientierungshilfe IKT-Risiken bei KI (12/2025); Aufsichtsmitteilung Cloud (02/2024)	Erwartungsbild der Aufsicht; nicht verbindlich, aber Maßstab für Prüfungen und Gespräche	IKT-Risikomanagement; Revision
KI-VO / KI-MIG	Art. 4, 50 VO (EU) 2024/1689; KI-Marktüberwachungsgesetz	KI-Kompetenz, Transparenz; BaFin als Marktüberwachung für KI mit Finanzbezug	Compliance
GwG	§§ 8, 43, 47 GwG	Aufzeichnungspflichten; Verbot der Informationsweitergabe bei Verdachtsmeldungen	Geldwäschebeauftragter
BetrVG	§ 87 Abs. 1 Nr. 6, § 90 BetrVG	Mitbestimmung bei technischer Eignung zur Überwachung	Personal; Betriebsrat

Rolle des DSB: beraten, überwachen, verzahnen

Nach Art. 39 DSGVO unterrichtet und berät der DSB, überwacht die Einhaltung, sensibilisiert und schult und berät bei der DSFA (Art. 35 Abs. 2). DORA-Pflichten liegen beim Leitungsorgan (Art. 5 Abs. 2 lit. a DORA). Der Hebel des DSB liegt deshalb weniger darin, eigene Dokumente zu erzeugen, als darin, dass Datenflüsse, Rechtsgrundlagen und Löschfristen in die Dokumente der anderen Funktionen einfließen: in das Informationsregister, die IKT-Risikobewertung, die Vertragsprüfung und den Vorfalldprozess.



LESEHILFE

So lesen Sie die Kapitel

Jedes Kapitel erklärt zuerst, was gilt, und dann, was der DSB prüft oder einfordern sollte. Farbige Kennzeichnungen zeigen, aus welchem Rechtsrahmen eine Anforderung stammt und ob eine Tenant-Einstellung betroffen ist.

Kennzeichnung	Bedeutung
DSGVO	Anforderung aus DSGVO oder BDSG, einschließlich Leitlinien von DSK und EDPB
DORA	Anforderung aus DORA und den zugehörigen technischen Standards
ZAG · BaFin	Nationales Aufsichtsrecht und BaFin-Verlautbarungen
KI-VO	KI-Verordnung und deutsches Durchführungsgesetz
Tenant-Einstellung	Konkrete Einstellung in Microsoft 365, Purview oder Power Platform, die der DSB prüfen lassen sollte
Einschätzung	Eigene Einordnung der Copilotenschule, die sich aus den Quellen ableitet, dort aber nicht wörtlich steht

TEIL A

Aufsichtsrecht verstehen

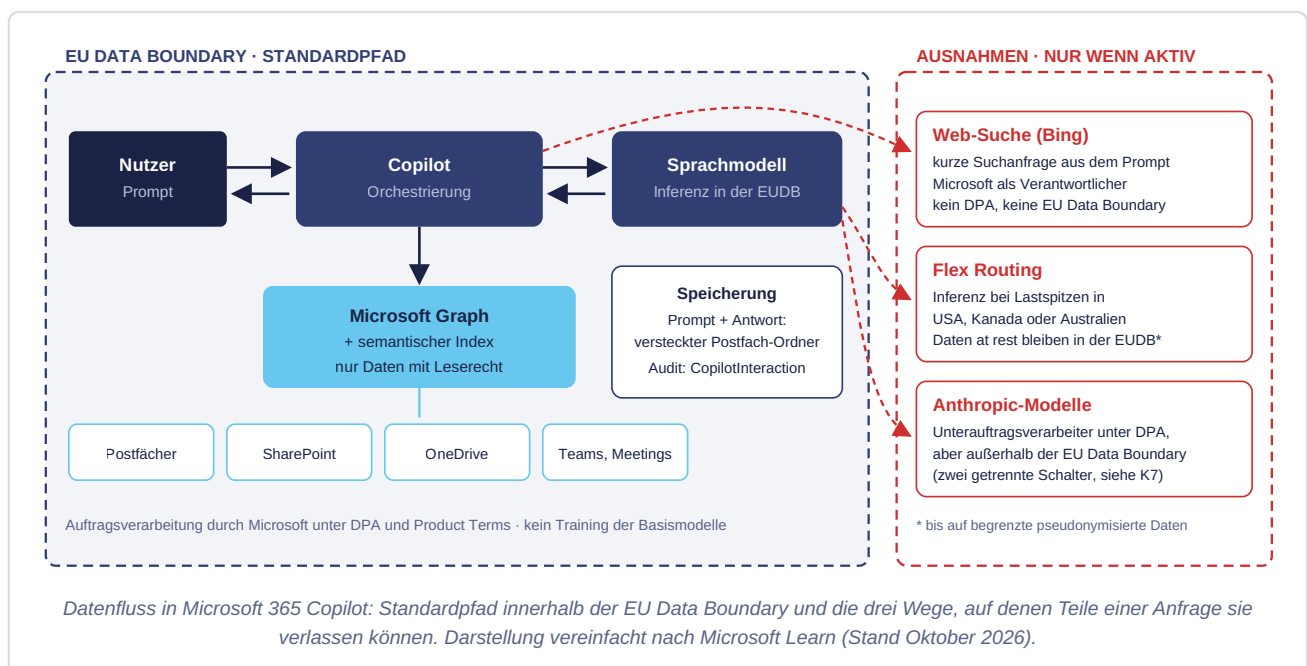
1 Wie Copilot mit Daten umgeht

DSGVO

Tenant-Einstellung

Bevor Copilot das Sprachmodell befragt, reichert er die Anfrage mit Inhalten aus dem eigenen Tenant an: E-Mails, Chats, Dateien, Kalender und Besprechungen, gefunden über Microsoft Graph und den semantischen Index. Microsoft sagt dazu klar: Copilot zeigt nur Daten, für die der Nutzer mindestens Leserechte hat. Es entstehen keine neuen Berechtigungen. Prompts, Antworten und über Graph abgerufene Daten werden laut Microsoft nicht zum Training der Basismodelle verwendet, und das Missbrauchs-Monitoring mit menschlicher Prüfung ist für Copilot abgeschaltet.

Prompt und Antwort samt Verweisen auf die genutzten Quellen werden gespeichert, und zwar in einem versteckten Ordner im Exchange-Postfach des jeweiligen Nutzers. Weder Nutzer noch Admins sehen diesen Ordner direkt, eDiscovery kann ihn aber durchsuchen. Jede Interaktion erzeugt zusätzlich einen Audit-Datensatz vom Typ `CopilotInteraction`. Für Kunden in der EU ist Copilot laut Microsoft ein Dienst innerhalb der EU Data Boundary.



WAS DER DSB PRÜFT

Der Standardpfad ist datenschutzrechtlich gut beschrieben und vertraglich abgesichert. Die Prüfarbeit liegt an zwei Stellen: bei den Berechtigungen, weil Copilot alles findet, was zu weit offen steht (K8), und bei den Ausnahmen rechts in der Grafik, weil sie teils standardmäßig aktiv sind (K7). Ein dritter Punkt ist die Speicherung: Was Copilot im Postfach ablegt, unterliegt den Aufbewahrungsrichtlinien des Instituts, nicht automatisch einem Copilot-spezifischen Löschkonzept (K9).

2

DORA: Copilot ist IKT-Asset und IKT-Dienstleistung

DORA

ZAG · BaFin

Zahlungsinstitute fallen nach Art. 2 Abs. 1 lit. b DORA in den Anwendungsbereich, und zwar ausdrücklich einschließlich der nach PSD2 befreiten Institute. Seit dem 17. Januar 2025 gilt die Verordnung. Den vereinfachten Rahmen nach Art. 16 können nur Institute nutzen, die nach Art. 32 PSD2 von der Zulassung befreit sind. Ein Zahlungsinstitut mit Erlaubnis nach § 10 ZAG muss deshalb den vollen IKT-Risikomanagementrahmen der Art. 5 bis 15 umsetzen und nach Art. 28 Abs. 2 eine Strategie für das IKT-Drittparteienrisiko führen.

Copilot ist darin doppelt erfasst. Als Software ist er Teil der Netzwerk- und Informationssysteme des Instituts. Die BaFin formuliert es in ihrer KI-Orientierungshilfe so: Ein KI-System ist eine Kombination von IKT-Assets und IKT-Infrasstruktur, das Modell selbst ein IKT-Asset (Software). KI-Systeme sind wie andere IKT-Assets in den Rahmen nach Art. 6 und Art. 8 bis 14 DORA zu integrieren: Inventar, Schutz, Erkennung, Reaktion, Wiederherstellung, Schulung. Als Cloud-Dienst ist Copilot zugleich eine IKT-Dienstleistung im Sinne von Art. 3 Nr. 21 DORA. Damit greifen für den Vertrag mit Microsoft die Art. 28 bis 30.

Die Verantwortung liegt nach Art. 5 Abs. 2 lit. a DORA beim Leitungsorgan, das nach Art. 5 Abs. 4 ausreichendes Wissen über IKT-Risiken haben und sich dafür regelmäßig schulen muss. Die BaFin-Orientierungshilfe beschreibt, wie Finanzunternehmen das für KI umsetzen: oftmals mit einer KI-Strategie, die das Leitungsorgan genehmigt, und mit definierten Verantwortlichkeiten für die Nutzung KI-generierter Ergebnisse.

Microsoft ist seit November 2025 kritischer IKT-Drittdienstleister

Am 18. November 2025 haben EBA, EIOPA und ESMA die Liste der kritischen IKT-Drittdienstleister veröffentlicht. Sie enthält 19 Anbieter, darunter „Microsoft Ireland Operations Limited“. Microsoft unterliegt damit der direkten europäischen Überwachung. Das entlastet das Institut nicht: Nach Art. 28 Abs. 1 lit. a DORA bleibt es jederzeit voll verantwortlich für die Einhaltung seiner Pflichten. **Einschätzung:** Erkenntnisse aus der europäischen Überwachung können die eigene Due Diligence stützen, ersetzen sie aber nicht.

WARUM DAS DEN DSB BETRIFFT

DORA schützt ausdrücklich die Vertraulichkeit von Daten: Ein IKT-bezogener Vorfall ist nach Art. 3 Nr. 8 ein ungeplantes Ereignis, das die Sicherheit der Netzwerk- und Informationssysteme beeinträchtigt und nachteilige Auswirkungen unter anderem auf die Vertraulichkeit von Daten hat. Datenklassifizierung, Zugriffsverwaltung nach dem Prinzip der geringsten Rechte und Protokollierung verlangt DORA ebenso wie Art. 32 DSGVO. Wer die technischen und organisatorischen Maßnahmen für Copilot einmal gemeinsam mit dem IKT-Risikomanagement beschreibt, hat zwei Nachweise mit einem Aufwand.

3 ZAIT aufgehoben, ZAG-MaRisk und § 26 ZAG bleiben

ZAG · BaFin

DORA

Die Zahlungsdienstenaufsichtlichen Anforderungen an die IT (ZAIT, Rundschreiben 11/2021) sind mit Ablauf des 16. Januar 2025 aufgehoben. Ihre Themen regelt jetzt DORA. Wer noch mit ZAIT-Kapiteln argumentiert, argumentiert mit einem Dokument, das es nicht mehr gibt.

National bleibt für Zahlungsinstitute ein eigenes Rundschreiben maßgeblich: die **Mindestanforderungen an das Risikomanagement von ZAG-Instituten (ZAG-MaRisk, Rundschreiben 07/2024 (BA) vom 27. Mai 2024)**, erlassen auf Grundlage von § 27 Abs. 1 ZAG. Die allgemeinen MaRisk, inzwischen in der Fassung vom 30. Juni 2026, richten sich an Kredit- und Finanzdienstleistungsinstitute, nicht an ZAG-Institute. Für die Copilot-Einführung sind in den ZAG-MaRisk vor allem relevant: das interne Kontrollsystem (AT 4.3), die Dokumentation, die für sachkundige Dritte nachvollziehbar sein und grundsätzlich fünf Jahre aufbewahrt werden muss (AT 6), die technisch-organisatorische Ausstattung (AT 7.2), das Notfallmanagement (AT 7.3), Änderungen betrieblicher Prozesse (AT 8.2) und die Auslagerung (AT 9).

Lücke im Detail

Die MaRisk 2026 stellen klar, dass IKT-Dienstleistungen, die dem DORA-Drittparteienrisikomanagement unterliegen, nicht in den Anwendungsbereich ihres AT 9 fallen. Eine entsprechende Klarstellung enthalten die ZAG-MaRisk von 2024 nach unserer Recherche nicht. **Einschätzung:** Bis die BaFin hier nachzieht, sollte das Institut beide Anforderungssätze dokumentiert bedienen, statt sich auf eine Analogie zu verlassen.

Unabhängig davon gilt § 26 ZAG. Er erfasst die Auslagerung wesentlicher Aktivitäten ausdrücklich einschließlich IKT-Systeme, verlangt ein Auslagerungsregister für wesentliche und nicht wesentliche Auslagerungen und eine Mitteilung an BaFin und Bundesbank, bevor wesentliche betriebliche Aufgaben ausgelagert werden. Die BaFin sagt dazu: DORA ergänzt die sektoralen Auslagerungsregeln, beide sind grundsätzlich parallel zu beachten. IKT-Auslagerungen werden weiter über das MVP-Verfahren „Anzeige von Auslagerungen“ angezeigt, und das DORA-Informationsregister ersetzt das Auslagerungsregister nach ZAG nicht.

Pflicht	Grundlage	Auslöser	Bezug zu Copilot
DORA-Informationsregister	Art. 28 Abs. 3 DORA; DurchfVO (EU) 2024/2956	jede vertragliche Vereinbarung über IKT-Dienstleistungen	Microsoft-Vertrag mit Copilot- Lizenzen und Unterauftrags- verarbeitern; jährliche Einrei- chung über das MVP-Portal im von der BaFin festgelegten Zeitraum (2026: 9. bis 30. März, Stichtag 31. Dezember)
Information der BaFin über ge- plante Verträge	Art. 28 Abs. 3 UAbs. 5 DORA	Vereinbarung unterstützt eine kritische oder wichtige Funkti- on	abhängig von der Einstufung (K4)
Auslagerungsregister	§ 26 Abs. 1 ZAG	wesentliche und nicht wesent- liche Auslagerungen	Einordnung als Auslagerung oder sonstiger Fremdbezug mit dem Auslagerungsmana- gement klären
Anzeige wesentlicher Auslage- rung	§ 26 Abs. 2 und 4 ZAG	beabsichtigte Auslagerung we- sentlicher betrieblicher Aufga- ben; Änderungen	Einschätzung: eher bei Agenten in Kernprozessen als beim Büroassistenten

Für die Cloud-Fragen verweist die BaFin weiter auf ihre **Aufsichtsmitteilung zu Auslagerungen an Cloud-Anbieter** vom 1. Februar 2024. Sie richtet sich ausdrücklich auch an Zahlungs- und E-Geld-Institute, ist aber noch nicht auf das geltende DORA-Recht umgeschrieben, sondern enthält „Ausblick DORA“-Kästen.

4 Die Einstufungsfrage: kritische oder wichtige Funktion?

DORA

Kaum eine Entscheidung bestimmt den Aufwand so stark wie diese. DORA unterscheidet zwischen IKT-Dienstleistungen, die eine kritische oder wichtige Funktion unterstützen, und allen übrigen. Kritisch oder wichtig ist nach Art. 3 Nr. 22 eine Funktion, deren Störung die finanzielle Leistungsfähigkeit, die Solidität oder die Fortführung der Geschäftstätigkeit erheblich beeinträchtigen würde, oder deren Ausfall die Einhaltung der Zulassungsbedingungen gefährden würde.

Folge	Jede IKT-Dienstleistung	Zusätzlich bei kritischer oder wichtiger Funktion
Vertrag	Pflichtinhalte nach Art. 30 Abs. 2	erweiterte Inhalte nach Art. 30 Abs. 3, unter anderem vollständige SLA, Prüf- und Zugangsrechte, Exit mit Übergangsfrist
Aufsicht	Eintrag im Informationsregister	rechtzeitige Information der BaFin über die geplante Vereinbarung
Exit	Kündigungsrechte nach Art. 28 Abs. 7	dokumentierte, getestete Exit-Strategie nach Art. 28 Abs. 8
Leitlinie	Risikobewertung und Due Diligence nach Art. 28 Abs. 4	Leitlinie nach DelVO (EU) 2024/1773; Unterauftragsvergabe nach DelVO (EU) 2025/532

Die BaFin-Orientierungshilfe zu KI gibt einen Hinweis zur Verhältnismäßigkeit: KI in kritischen oder wichtigen Funktionen braucht umfangreichere Kontrollen als KI-basierte Self-Service-Assistenten, die vollständig unter menschlicher Überwachung stehen.

Einschätzung: Copilot als Schreib-, Such- und Zusammenfassungsassistent unter menschlicher Kontrolle unterstützt für sich genommen in der Regel keine kritische oder wichtige Funktion. Das ändert sich, sobald Agenten in Zahlungs-, Betrugs-, Beschwerde- oder Meldeprozesse eingreifen oder Prozesse so stark von Copilot abhängen, dass ein Ausfall sie stört. Zu beachten ist auch der Rahmenvertrag: Hat das Institut Microsoft 365 insgesamt als Unterstützung kritischer Funktionen eingestuft (E-Mail, Teams), fällt Copilot vertraglich unter diesen Rahmen. Die Einstufungsfrage betrifft dann vor allem die konkreten Nutzungsszenarien.

WAS DER DSB EINFORDERT

Die Einstufung trifft nicht der DSB. Er sollte aber darauf bestehen, dass sie auf denselben Nutzungsszenarien beruht wie die DSFA. Ein Use-Case-Katalog, der für beide Prüfungen gilt, verhindert, dass IKT-Risikomanagement einen harmlosen Büroassistenten bewertet, während die DSFA bereits Agenten mit Schreibzugriff auf Kundendaten beschreibt.

5

Was die BaFin-Orientierungshilfe zu KI erwartet

ZAG · BaFin

DORA

Am 18. Dezember 2025 hat die BaFin die „Orientierungshilfe zu IKT-Risiken beim Einsatz von KI in Finanzunternehmen“ veröffentlicht, 38 Seiten. Die BaFin betont selbst, dass es sich um eine nicht verpflichtende Hilfestellung handelt, keine verbindliche DORA-Auslegung, und um ein „lebendes Dokument“. Adressaten sind Finanzunternehmen, die den vollen Rahmen der Art. 5 bis 15 DORA anwenden, also auch Zahlungsinstitute nach § 10 ZAG. In Prüfungen und Aufsichtsgesprächen wird sie trotzdem der Maßstab sein, an dem sich ein Institut messen lassen muss.

Für den DSB ist vor allem die Fallstudie ab Seite 28 interessant: ein LLM-basierter KI-Assistent, der Texte, E-Mails und Präsentationen erstellt. Die BaFin unterscheidet drei Varianten: On-Premise, Cloud im eigenen Tenant und Cloud außerhalb des Tenants. Die dritte Variante tritt nach der BaFin typischerweise auf, wenn ein Sprachmodell aus Standardsoftware heraus aufgerufen wird, gegebenenfalls ohne Kenntnis des Nutzers. Das Hauptrisiko: Daten verlassen den Tenant.

Einschätzung: Für Microsoft 365 Copilot ist Variante 2 der Normalfall. Merkmale der Variante 3 treten dort auf, wo Teile einer Anfrage den Microsoft-365-Rahmen verlassen: bei der Bing-Websuche, bei Drittanbieter-Modellen und bei Agenten, die externe Dienste ansprechen. Genau diese Punkte behandelt Kapitel 7.

Maßnahme aus der BaFin-Fallstudie	Mögliche Umsetzung in Microsoft 365 (Einschätzung)
Klassifizierung der Daten nach Vertraulichkeitsstufen	Sensitivity Labels mit Auto-Labeling; Labels mit Verschlüsselung für Hochrisiko-Inhalte
Zero-Trust: Assistent ruft nur autorisierte Daten ab	Berechtigungsvereinigung, Restricted Content Discovery, Restricted Access Control
MFA und Conditional Access	Entra ID Conditional Access für Copilot-Nutzer und Agent-Identitäten
Auditing-Framework, das alle Anfragen protokolliert	Purview Audit (CopilotInteraction), eDiscovery, DSPM for AI
Schutz vor Prompt Injection	Auswertung der Audit-Felder zu erkannten Injection- und Jailbreak-Versuchen; Begrenzung externer Inhalte als Wissensquelle
Monitoring gegen Ausgabe vertraulicher Informationen an Unberechtigte	DSPM for AI, DLP-Richtlinie für Copilot
Human-in-the-Loop	Arbeitsanweisung: Ergebnisse mit Kunden- oder Aufsichtswirkung werden vor Verwendung geprüft
Funktionsbeschränkungen	Web-Suche-Policy, Steuerung der Modellanbieter, Agenten-Freigabe, gestaffelte Lizenzzuweisung
Stilllegung mit Löschung der verwendeten Daten und historischen KI-Interaktionen nach DSGVO	Purview-Aufbewahrungsrichtlinien, Löschkonzept, Exit-Plan

Linke Spalte nach BaFin-Orientierungshilfe (Dezember 2025), rechte Spalte eigene Zuordnung.

Zwei weitere Aussagen der Orientierungshilfe sollte der DSB kennen. Erstens beschreibt die BaFin, dass viele Finanzunternehmen risikobasierte Nutzungsvorgaben treffen, abhängig von der Kritikalität der Daten und vom Ort der Verarbeitung. Eine aufsichtliche Erwartung formuliert sie damit ausdrücklich nicht, ein Prüfer wird aber danach fragen. Das ist dieselbe Logik wie die Datenschutzfrage, welche Daten in welchen Copilot-Modus dürfen. Zweitens hält sie fest, dass die Meldepflichten nach DORA auch Vorfälle in KI-Systemen umfassen können, und empfiehlt, solche Vorfälle zu kennzeichnen (K12).

TEIL B

Datenschutz prüfen

6 Rollen, Zwecke und Rechtsgrundlagen

DSGVO

ZAG · BaFin

WER IST WAS?

Das Institut ist Verantwortlicher. Für Microsoft 365 Copilot und Copilot Chat mit Enterprise Data Protection handelt Microsoft als Auftragsverarbeiter unter DPA und Product Terms. Drei Konstellationen weichen davon ab und gehören deshalb ausdrücklich in das Verzeichnis der Verarbeitungstätigkeiten und die DSFA:

- **Bing-Web Suche:** Für die generierten Suchanfragen ist Microsoft nach eigener Darstellung Verantwortlicher. Das DPA gilt dafür nicht, ebenso wenig die EU Data Boundary (K7).
- **Agenten und Connectoren von Drittanbietern:** Microsoft verweist auf Datenschutzerklärung und Nutzungsbedingungen des jeweiligen Agenten. Der Anbieter kann eigener Verantwortlicher oder weiterer Empfänger sein.
- **„Anthropic models with Data Retention“:** Werden diese Modelle freigeschaltet, handelt Anthropic als unabhängiger Verarbeiter unter eigenen Bedingungen, außerhalb von DPA und Product Terms. Standardmäßig sind sie aus.

ZWECKBINDUNG

Die DSK verlangt in ihrer Orientierungshilfe „Künstliche Intelligenz und Datenschutz“ (Mai 2024), den Einsatzzweck vorab festzulegen und für jeden Verarbeitungsschritt eine Rechtsgrundlage zu haben. Ihre Orientierungshilfe zu RAG-Systemen (Oktober 2025) weist zusätzlich darauf hin, dass bei der Übergabe personenbezogener Daten aus der Datenbasis an das Sprachmodell eine Verkettung mit Daten im Modell droht, die in der Ausgabe nicht erkennbar ist, und dass Zweckbindung technisch über Rollen und eine funktionale Trennung der Datenbasis umzusetzen ist. Für Copilot heißt das praktisch: ein Katalog erlaubter und ausgeschlossener Anwendungsfälle. Ausgeschlossen werden sollten mindestens Entscheidungen mit Rechtswirkung gegenüber Kunden ohne menschliche Prüfung (Art. 22 DSGVO) und jede Auswertung zur Leistungs- oder Verhaltenskontrolle von Beschäftigten.

KUNDENDATEN IM ZAHLUNGSVERKEHR

§ 59 Abs. 2 ZAG, der Art. 94 Abs. 2 PSD2 umsetzt, erlaubt Zahlungsdienstleistern, die für die Zahlungsdienste notwendigen personenbezogenen Daten nur mit ausdrücklicher Einwilligung des Zahlungsdienstnutzers zu verarbeiten. Der EDPB hat in seinen Leitlinien 06/2020 klargestellt, dass diese „ausdrückliche Einwilligung“ vertraglicher Natur ist und keine Einwilligung im Sinne der DSGVO. Die Rechtsgrundlage ergibt sich weiter aus Art. 6 DSGVO. Der EDPB weist dort auch darauf hin, dass Transaktionsdaten besondere Kategorien nach Art. 9 DSGVO offenlegen können, etwa durch Spenden an Parteien oder Religionsgemeinschaften oder Zahlungen an Ärzte.

Einschätzung: Wer Transaktionsdaten, Beschwerden oder Chargeback-Vorgänge mit Copilot auswertet oder zusammenfasst, nutzt sie für einen Zweck, der zum Zahlungsdienstvertrag passen oder eine eigene Rechtsgrundlage haben muss, etwa eine rechtliche Verpflichtung. Zusammenfassungen über viele Transaktionen können Art.-9-Informationen erst sichtbar machen. Solche Auswertungen gehören deshalb in den Use-Case-Katalog und die DSFA, nicht in die freie Nutzung.

BESCHÄFTIGTENDATEN

Copilot verarbeitet zwangsläufig Beschäftigtendaten: Prompts, E-Mails, Chats, Transkripte und Audit-Daten. Der EuGH hat mit Urteil vom 30. März 2023 (C-34/21) entschieden, dass nationale Generalklauseln, die die Anforderungen von Art. 88 Abs. 2 DSGVO nicht erfüllen, nicht anwendbar sind. Betroffen war eine hessische Vorschrift, die § 26 Abs. 1 Satz 1 BDSG entspricht. Mit Urteil vom 19. Dezember 2024 (C-65/23) hat er ergänzt: Auch Betriebsvereinba-

rungen müssen Art. 5, Art. 6 Abs. 1 und Art. 9 DSGVO einhalten, und Gerichte prüfen die Erforderlichkeit vollständig.

Einschätzung: Tragende Rechtsgrundlagen sind damit Art. 6 Abs. 1 lit. b, c oder f DSGVO. Die Betriebsvereinbarung konkretisiert und begrenzt, kann aber keine fehlende Rechtsgrundlage ersetzen. Die Mitbestimmung nach § 87 Abs. 1 Nr. 6 BetrVG behandelt der Betriebsrats-Leitfaden.

7

EU Data Boundary: die Ausnahmen kennen

DSGVO

DORA

Tenant-Einstellung

„Copilot ist ein EU-Data-Boundary-Dienst“ stimmt, aber es stimmt nicht für jede Funktion und nicht unabhängig von der Konfiguration. 2026 hat Microsoft mehrere Optionen eingeführt, die Verarbeitung außerhalb der EU Data Boundary zulassen, und einige davon sind für neue Tenants standardmäßig aktiv. Für ein beaufsichtigtes Institut sollte jede dieser Einstellungen eine dokumentierte Entscheidung sein, nicht ein Zufall des Anlagedatums.

Funktion	Was passiert	Standard laut Microsoft	Ort der Einstellung	Vorschlag (Einschätzung)
Web-Suche (Bing)	Copilot erzeugt aus dem Prompt eine kurze Suchanfrage. Microsoft ist dafür Verantwortlicher; DPA und EU Data Boundary gelten nicht. Keine Nutzung für Werbung oder Training laut Product Terms.	verfügbar, solange die Cloud Policy nicht konfiguriert ist; Nutzer sehen einen Schalter „Webinhalte“	Cloud Policy Service: „Allow web search in Copilot“	bewusst entscheiden; mindestens per DLP sperren, wenn der Prompt sensible Informationen enthält
Flex Routing	Bei Lastspitzen findet die Inferenz in den USA, Kanada oder Australien statt. Gespeicherte Daten bleiben in der EUDB, bis auf begrenzte pseudonymisierte Daten.	aktiv für berechnete Tenants, die nach dem 25.03.2026 angelegt wurden; ältere Tenants prüfen	M365 Admin Center > Copilot > Einstellungen > „Flex routing during peak load periods“	„Do not allow“, sofern keine Transfer-Bewertung vorliegt; Power Platform folgt der restriktiveren Einstellung
Anthropic als Unterauftragsverarbeiter	Claude-Modelle in Copilot, Researcher und Copilot Studio unter DPA, aber außerhalb der EU Data Boundary	EU/EFTA/UK: „No users“	„AI providers operating as Microsoft subprocessors“	nur nach eigener Bewertung und auf Gruppen begrenzt aktivieren
Anthropic in Word, Excel, PowerPoint	eigene Einstellung seit 03.04.2026; Verarbeitung außerhalb der EU Data Boundary	aktiv für EU-Tenants, die nach dem 25.03.2026 angelegt wurden; ältere Tenants: Message Center	„Copilot in Microsoft 365 apps with Anthropic models“	Status prüfen lassen und dokumentieren
OpenAI als Unterauftragsverarbeiter	von OpenAI betriebene Modelle; in der EUDB bis auf dokumentierte Teilübermittlungen; ausgenommen von In-Country-Zusagen	seit 24.07.2026 für alle Nutzer berechtigter Kunden aktiv	„AI providers operating as Microsoft subprocessors“	in VVT, DSFA und Informationsregister aufnehmen; aktiv entscheiden
Anthropic-Modelle mit Datenaufbewahrung	Anthropic als unabhängiger Verarbeiter nach eigenen Bedingungen; Speicherung bis 30 Tage, bei Verstößen gegen Nutzungsrichtlinien länger	aus	eigene Opt-in-Steuerung	aus lassen

Quelle: Microsoft Learn, abgerufen Oktober 2026. Voreinstellungen ändern sich; maßgeblich ist der aktuelle Stand im Tenant.

Zur Modellwahl: Im Copilot Chat entscheidet im Modus „Auto“ ein Router, welches Modell antwortet; Microsoft dokumentiert nicht, welche Modelle dahinterstehen. Für Copilot Cowork sagt Microsoft, dass Auto nur aus den von der Organisation freigegebenen Modellen wählt. **Einschätzung:** Dieselbe Logik liegt für den Chat nahe, ist aber nicht belegt. Belegt ist, dass Anthropic in EU-Tenants nur nach ausdrücklicher Freigabe verfügbar ist und dass der Audit-Datensatz den Modellanbieter nur bei ausdrücklicher Wahl durch den Nutzer sicher enthält (K9).

Warum das aufsichtsrechtlich relevant ist

Art. 30 Abs. 2 lit. b DORA verlangt im Vertrag die Orte der Leistungserbringung und Datenverarbeitung und eine Vorab-Mitteilung bei Änderungen. Art. 29 Abs. 2 DORA verlangt für Dienstleistungen, die kritische oder wichtige Funktionen unterstützen, bei Bezug zu Drittstaaten die Einhaltung des EU-Datenschutzrechts und die Rechtsdurchsetzung zu prüfen. **Einschätzung:** Die Aufnahme von OpenAI in die Unterauftragsverarbeiterliste im Juni 2026 mit Aktivierung für alle Nutzer ab Juli ist genau der Fall, für den Institute einen Änderungsprozess brauchen: Wer erhält die Mitteilung, wer bewertet sie, und bis wann wird entschieden?

Zwei weitere Punkte gehören in diese Prüfung. Erstens die Speicherung im Land: Für berechnete Tenants mit Standardgeografie Deutschland gibt es seit dem 14. September 2026 die Einstellung „Store Microsoft 365 customer data in-country“ (Admin Center > Einstellungen > Organisationsprofil > Datenspeicherort). Sie betrifft Exchange, SharePoint, OneDrive, Teams sowie Copilot und Copilot Chat. Für danach angelegte Tenants ist sie standardmäßig aus, ältere Tenants finden ihren Stand im Message Center. Ab dem 14. Dezember 2026 wird die Auswahl wirksam: Steht sie auf „Off“, darf Microsoft diese Daten regional innerhalb der EU Data Boundary speichern und verschieben, also auch außerhalb Deutschlands. Die EU-Data-Boundary-Zusage bleibt davon unberührt. **Einschätzung:** Rechtlich ist das kein Drittlandtransfer, wohl aber eine Änderung des Datenverarbeitungsorts nach Art. 30 Abs. 2 lit. b DORA, die in Informationsregister und Vertragsdokumentation nachzuziehen ist, wenn das Institut bislang mit Speicherung in Deutschland argumentiert. Zweitens Copilot Chat ist nur dann durch Enterprise Data Protection geschützt, wenn Beschäftigte mit ihrem Arbeitskonto angemeldet sind, erkennbar am grünen Schild. Private Microsoft-Konten auf Dienstgeräten lassen sich über Tenant Restrictions v2 unterbinden.

8 Oversharing ist im Zahlungsinstitut ein Vertraulichkeitsproblem

DSGVO

DORA

Tenant-Einstellung

Copilot schafft keine neuen Zugriffe, aber er findet zuverlässig, was schon offen stand. In einem Industrieunternehmen ist das ärgerlich, wenn eine Gehaltsliste auftaucht. In einem Zahlungsinstitut liegen auf Laufwerken und Sites Inhalte, deren unkontrollierte Sichtbarkeit aufsichtsrechtliche Folgen haben kann: KYC-Unterlagen mit Ausweiskopien, PEP-Prüfungen, Betrugs- und Chargeback-Fälle, Kundenbeschwerden, interne Prüfberichte und Verdachtsfälle nach dem Geldwäschegesetz.

— VERDACHTSMELDUNGEN: DER HEIKELSTE FALL

§ 47 Abs. 1 GwG verbietet Verpflichteten, den Vertragspartner, den Auftraggeber der Transaktion und sonstige Dritte über eine beabsichtigte oder erstattete Verdachtsmeldung nach § 43 GwG oder ein daraufhin eingeleitetes Ermittlungsverfahren in Kenntnis zu setzen. **Einschätzung:** Interne Sichtbarkeit ist für sich genommen kein Verstoß gegen § 47 GwG. Sie vergrößert aber den Kreis der Mitwissenden und damit das Risiko einer unbedachten Weitergabe, etwa wenn ein Kundenberater eine Copilot-Zusammenfassung mit Hinweisen auf einen Verdachtsfall erhält. Unterlagen zu Verdachtsfällen gehören deshalb in streng begrenzte Bereiche, die von Copilot ausgenommen sind.

— BANKGEHEIMNIS UND VERTRAULICHKEIT

Ein allgemeines gesetzliches Bankgeheimnis gibt es in Deutschland nicht; es beruht nach Darstellung des Wissenschaftlichen Dienstes des Bundestags im Wesentlichen auf vertraglicher Vereinbarung. **Einschätzung:** Für Zahlungsinstitute folgt die Vertraulichkeit aus Vertrag und AGB, aus der DSGVO, aus § 59 ZAG und aus dem Schutzziel Vertraulichkeit unter DORA. Wird sie durch Oversharing verletzt, dürfte das in vielen Fällen ein IKT-bezogener Vorfall nach Art. 3 Nr. 8 DORA sein und gegebenenfalls zugleich eine Verletzung des Schutzes personenbezogener Daten (K12).

— WERKZEUGE, DIE DER DSB KENNEN SOLLTE

Werkzeug	Wirkung
DSPM for AI (Purview)	Oversharing-Assessment, Activity Explorer mit Prompts, Antworten und Web-Suchanfragen, Erkennung riskanter Interaktionen
SharePoint Advanced Management	laut Microsoft in der Copilot-Lizenz enthalten; Data-Access-Governance-Berichte, Site Access Reviews, Restricted Access Control
Restricted Content Discovery	hält Sites aus Suche und Copilot heraus, ohne Berechtigungen zu ändern; schaltet auch SharePoint-Agenten auf der Site ab
Sensitivity Labels	bei Verschlüsselung braucht der Nutzer die Rechte VIEW und EXTRACT, sonst fasst Copilot nicht zusammen; Labels vererben sich auf erzeugte Inhalte
DLP für Copilot	schließt gelabelte Dateien und Mails von der Verarbeitung aus; Blockieren von Prompts mit sensiblen Informationstypen laut Microsoft in Vorschau

Restricted SharePoint Search ist kein Ausweg mehr: Seit dem 31. Juli 2026 kann die Funktion nicht neu aktiviert werden, Nachfolger ist Restricted Content Discovery. Die DSK verlangt in ihrer Orientierungshilfe zu technischen und organisatorischen Maßnahmen bei KI-Systemen (Juni 2025) für RAG-Systeme, bei jeder Aktualisierung der Datenquellen zu prüfen, ob die Nutzer auf die neuen Daten zugreifen dürfen. Ihre Orientierungshilfe zu generativen KI-Systemen mit RAG-Methode (Oktober 2025) ergänzt, dass die Vertraulichkeit allein über Mandantentrennung und das Rechte- und Rollenkonzept der Referenzdokumente hergestellt wird, weil sich im Sprachmodell selbst nicht steuern lässt, worauf einzelne Nutzer zugreifen dürfen. Für Copilot sind die Berechtigungen in SharePoint, OneDrive, Exchange und Teams dieses Rollenkonzept. Das ist die Oversharing-Frage als laufende Pflicht, nicht als einmaliges Projekt. Die Einstellungen im Detail beschreibt der Admin-Leitfaden.

9 Protokollierung, Aufbewahrung, Löschung

DSGVO

ZAG · BaFin

Tenant-Einstellung

Hier treffen die Rahmen am härtesten aufeinander. Die Aufsicht will Nachvollziehbarkeit: § 27 Abs. 1 Nr. 2 ZAG verlangt eine vollständige Dokumentation der Geschäftstätigkeit, die eine lückenlose Überwachung durch die BaFin gewährleistet, die ZAG-MaRisk verlangen nachvollziehbare Dokumentation mit grundsätzlich fünf Jahren Aufbewahrung, und die BaFin-Orientierungshilfe empfiehlt, KI-Interaktionen zu protokollieren. Die DSGVO verlangt Datenminimierung und Speicherbegrenzung. Und das Betriebsverfassungsrecht sieht in jeder Protokollierung von Nutzeraktivität eine mögliche Verhaltenskontrolle.

WAS TECHNISCH ENTSTEHT

Datenart	Ablage und Zugriff	Dauer ohne eigene Konfiguration
Interaktionsinhalte (Prompt, Antwort)	versteckter Ordner im Postfach des Nutzers; eDiscovery, DSPM for AI; Nutzer können ihren Verlauf selbst löschen	richtet sich nach den Aufbewahrungsrichtlinien; eigene Location „Microsoft Copilot experiences“ in Purview
Audit-Datensatz CopilotInteraction	Purview Audit; enthält u. a. genutzte Ressourcen mit Label-ID, Agent, Nutzung der Web-Suche, erkannte Injection-Versuche; Modellanbieter und Modellname nur, wenn der Nutzer ein Modell ausdrücklich gewählt hat, im Auto-Modus laut Microsoft nicht für jede Anfrage	Audit (Standard): 180 Tage. Auch mit Audit (Premium) gilt die 1-Jahres-Standardrichtlinie nur für bestimmte Workloads; für Copilot ist eine eigene Richtlinie nötig
Gesprächsprotokolle von Copilot-Studio-Agenten	Dataverse, Tabelle <code>ConversationTranscript</code> ; Speicherung pro Umgebung abschaltbar	standardmäßig 30 Tage, änderbar

Zwei technische Details gehören in das Löschkonzept: Auch eine Richtlinie „nach einem Tag löschen“ kann laut Microsoft bis zu 16 Tage bis zur endgültigen Löschung brauchen, und Holds (Litigation Hold, eDiscovery Hold) setzen die Löschung aus. Scheidet ein Nutzer aus, bleiben die Daten im inaktiven Postfach erhalten, wenn eine Aufbewahrungsrichtlinie greift.

EIN VORSCHLAG ZUR AUFLÖSUNG

Klasse	Grundsatz	Umsetzung (Beispiel)
Arbeitshilfe	Copilot-Chats sind keine Geschäftsunterlagen. Was geschäftsrelevant ist, wird als Ergebnis im führenden System abgelegt und unterliegt dessen Frist.	kurze Aufbewahrung der Interaktionsinhalte, etwa wenige Monate, dann Löschung
Sicherheitsnachweis	Audit-Metadaten dienen Vorfallaufklärung und Kontrolle der Zugriffe, nicht der Leistungsbewertung.	eigene Audit-Richtlinie, etwa ein Jahr; Zugriff nur für benannte Rollen, Vier-Augen-Prinzip, Zweckbindung in der Betriebsvereinbarung
Pflichtdokumentation	GwG-Aufzeichnungen, Begründungen zu Verdachtsmeldungen und aufsichtsrelevante Entscheidungen existieren nie nur in einem Copilot-Chat.	Arbeitsanweisung: Dokumentation im vorgesehenen System; § 8 GwG verlangt fünf Jahre Aufbewahrung

Die Klassen und Beispielwerte sind eine Einschätzung der Copilotenschule und mit Revision, IKT-Risikomanagement und Betriebsrat abzustimmen.

10 Datenschutz-Folgenabschätzung

DSGVO

DORA

Die DSK schreibt in ihrer KI-Orientierungshilfe, dass beim Einsatz von KI-Anwendungen eine DSFA „vielfach“ erforderlich sein wird. Ihre Muss-Liste nennt die umfangreiche Verarbeitung von Daten über das Verhalten von Beschäftigten, die zur Bewertung ihrer Arbeitstätigkeit so eingesetzt werden können, dass sich Rechtsfolgen ergeben oder die Betroffenen erheblich beeinträchtigt werden (Nr. 8), und den Einsatz von KI zur Steuerung der Interaktion mit Betroffenen oder zur Bewertung persönlicher Aspekte (Nr. 11). **Einschätzung:** In einem Zahlungsinstitut mit Kundendaten, Audit-Protokollierung und geplanten Agenten ist die DSFA als erforderlich zu behandeln.

Microsoft stellt Material bereit: eine „Build your own M365 Copilot DPIA“-Vorlage (Stand Juni 2025) und im Service Trust Portal den „Microsoft Copilot & Copilot Chat Risk Assessment Quickstart“. Die Vorlage stammt aus der Zeit vor Flex Routing, vor OpenAI als Unterauftragsverarbeiter und vor den Anthropic-Voreinstellungen von 2026. Sie ist ein Startpunkt, kein Ergebnis.

Zur Einordnung der Aufsichtslage: Die DSK hat im November 2022 festgestellt, dass ein datenschutzkonformer Betrieb von Microsoft 365 auf Basis des damaligen Datenschutznachtrags nicht nachgewiesen werden kann. Der Hessische Beauftragte für Datenschutz und Informationsfreiheit kam im November 2025 auf Basis des DPA vom September 2025 zu dem Ergebnis, dass ein datenschutzkonformer Betrieb möglich ist, wenn der Kunde seine eigenen Pflichten erfüllt. Geprüft wurde das DPA, nicht einzelne Produkte; Copilot war damit nicht Gegenstand der Bewertung. Eine Copilot-spezifische Stellungnahme einer deutschen Aufsichtsbehörde haben wir nicht gefunden.

Baustein der DSFA	Inhalt im Zahlungsinstitut
Systematische Beschreibung	Produkte und Lizenzgruppen, Datenquellen (Graph, Web, Agenten, Connectoren), aktive Modellanbieter, Speicherorte
Zwecke und Rechtsgrundlagen	Use-Case-Katalog; Kunden, Beschäftigte, Dritte; Bezug zu § 59 ZAG
Notwendigkeit	ausgenommene Bereiche (GwG, Personal, Betrug), Web-Suche, Aufbewahrungsklassen
Risiken	Oversharing, fehlerhafte Inhalte mit Kundenwirkung, Drittlandverarbeitung, Überwachung Beschäftigter, Prompt Injection über externe Inhalte, Agenten mit Schreibrechten
Maßnahmen	Labels, RCD, DLP, Richtlinien für Modellanbieter, Schulung, Betriebsvereinbarung, Audit-Konzept, Agenten-Freigabe
Abgleich mit DORA	gemeinsame Risikobasis mit der Bewertung nach Art. 28 Abs. 4 DORA; Verweis auf Informationsregister und Exit-Plan

TEIL C

Verträge, Vorfälle, KI-Verordnung

11 Verträge: DPA plus DORA-Klauseln

DORA

DSGVO

Art. 30 Abs. 2 DORA schreibt für jeden IKT-Vertrag Mindestinhalte vor, Art. 30 Abs. 3 weitere für kritische oder wichtige Funktionen. Viele davon überschneiden sich mit Art. 28 DSGVO. Microsoft hat ein Mapping-Dokument veröffentlicht, das den eigenen Vertragsstack gegen Art. 30 DORA und die RTS zur Unterauftragsvergabe abgleicht. Zum Stack gehören Product Terms, das Data Protection Addendum (aktuelle Fassung vom 22. Mai 2026), die Service Level Agreements, der Rahmenvertrag sowie für berechnigte Finanzunternehmen ein DORA-Addendum und das Financial Services Amendment. Wie das Addendum konkret bezogen wird, sollte das Institut über sein Microsoft-Account-Team klären.

Art. 30 Abs. 2 DORA	Prüffrage aus Datenschutzsicht
a) Beschreibung der Dienste; Bedingungen der Unterauftragsvergabe	Sind alle Unterauftragsverarbeiter erfasst, auch KI-Modellanbieter? Wie läuft das Widerspruchsrecht nach Art. 28 Abs. 2 DSGVO praktisch?
b) Orte der Leistungserbringung und Datenverarbeitung; Vorab-Mitteilung bei Änderungen	Deckt sich mit den EUDB-Ausnahmen aus K7? Wer im Institut empfängt die Mitteilungen?
c) Verfügbarkeit, Authentizität, Integrität, Vertraulichkeit einschließlich personenbezogener Daten	TOM-Anlage des DPA gegen die eigene Schutzbedarfsfeststellung
d) Zugang, Wiederherstellung und Rückgabe der Daten bei Insolvenz oder Beendigung	Export und Löschung der Copilot-Interaktionen im Exit-Fall
f) Unterstützung bei IKT-Vorfällen	Meldung von Datenschutzverletzungen nach Art. 33 Abs. 2 DSGVO; Fristen passend zum DORA-Takt?
g) Kooperation mit Aufsichts- und Abwicklungsbehörden	Auskunftsrechte der Datenschutzaufsicht ebenfalls abgedeckt?
h) Kündigungsrechte und Fristen	Kündigungsrecht bei wesentlichen Änderungen der Unterauftragsverarbeitung?
i) Teilnahme an Awareness-Programmen nach Art. 13 Abs. 6	Verzahnung mit der Datenschutzbildung

Ein Punkt verdient besondere Beachtung, weil er Datenschutz ausdrücklich in DORA verankert: Nach Art. 29 Abs. 2 DORA ist bei Vereinbarungen über IKT-Dienstleistungen, die kritische oder wichtige Funktionen unterstützen, mit Bezug zu einem Drittstaat unter anderem zu bewerten, ob das EU-Datenschutzrecht eingehalten und das Recht wirksam durchgesetzt werden kann. Microsoft Ireland sitzt zwar in der EU, Unterauftragsverarbeiter und Ausnahmen wie Flex Routing führen aber in Drittstaaten. **Einschätzung:** Auch ohne Einstufung als kritische Funktion ist diese Prüfung ein guter Maßstab für die eigene Transfer-Bewertung. Das Konzentrationsrisiko bei einem Anbieter, der E-Mail, Zusammenarbeit, Cloud-Infrastruktur und KI zugleich liefert, ist Teil derselben Bewertung.

12 Vorfälle: zwei Meldewege, zwei Uhren

DORA

DSGVO

Für Zahlungsinstitute ersetzt DORA die frühere Vorfalldmeldung nach PSD2. Art. 23 DORA erfasst auch zahlungsbezogene Betriebs- und Sicherheitsvorfälle. Parallel bleibt die Meldepflicht für Datenschutzverletzungen nach Art. 33 DSGVO bestehen. Beide Wege haben eigene Adressaten, eigene Schwellen und eigene Fristen.



Schwerwiegend ist ein IKT-bezogener Vorfall nach der Delegierten Verordnung (EU) 2024/1772, wenn er kritische Dienste betrifft und entweder ein erfolgreicher, böswilliger und unbefugter Zugriff vorliegt, der zu Datenverlusten führen kann, oder mindestens zwei weitere Schwellenwerte erreicht sind. Ein solcher erfolgreicher böswilliger Zugriff gilt dabei bereits selbst als Betroffenheit kritischer Dienste. Vertraulichkeit ist betroffen, wenn Daten einer unbefugten Partei oder einem unbefugten System zugänglich gemacht wurden. Sind finanzielle Interessen von Kunden betroffen, verlangt Art. 19 Abs. 3 DORA zusätzlich eine Information der Kunden.

Szenario	DORA	DSGVO
Copilot fasst für einen Beschäftigten eine zu weit freigegebene Gehaltsliste zusammen	IKT-bezogener Vorfall (Vertraulichkeit); in der Regel nicht schwerwiegend, weil kein böswilliger Zugriff und kein kritischer Dienst	Verletzung des Schutzes personenbezogener Daten; Meldung, wenn ein Risiko nicht ausgeschlossen werden kann
Prompt Injection über eine externe E-Mail führt dazu, dass ein Agent Kundendaten nach außen sendet	erfolgreicher böswilliger, unbefugter Zugriff; nach DeVO 2024/1772 (Art. 6 lit. c, Art. 8, Art. 9 Abs. 5 lit. b) regelmäßig schwerwiegend, wenn er zu Datenverlusten führen kann	meldepflichtig wahrscheinlich; Benachrichtigung der Betroffenen prüfen
Copilot-Ausfall von mehreren Stunden	Klassifizierung nach Dauer und betroffenen Funktionen; meist nicht schwerwiegend, wenn keine kritische Funktion abhängt	in der Regel keine Datenschutzverletzung

Die Zuordnung der Szenarien ist eine Einschätzung; maßgeblich ist die Klassifizierung im Einzelfall.

Die BaFin empfiehlt, KI-Vorfälle als solche zu kennzeichnen und mit Cloud-Anbietern Meldevereinbarungen zu treffen. Praktisch hilft ein gemeinsamer Triage-Bogen: ein Sachverhalt, zwei Bewertungen, zwei Uhren, die ab Kenntnis laufen. Der DSB sollte im DORA-Vorfallprozess als Pflichtbeteiligter benannt sein, sobald personenbezogene Daten betroffen sein können.

13 KI-Verordnung, KI-MIG und Schulungspflicht

KI-VO

DORA

ZAG · BaFin

Als Nutzer von Copilot ist das Institut Betreiber im Sinne der KI-Verordnung. Die Pflicht zur KI-Kompetenz (Art. 4) und die Verbote (Art. 5) gelten seit dem 2. Februar 2025. Die Digital-Omnibus-Verordnung zur KI (VO (EU) 2026/1744 vom 8. Juli 2026, ABl. L vom 24. Juli 2026) ist am 27. Juli 2026 in Kraft getreten. Sie verschiebt die Pflichten für Hochrisiko-Systeme nach Anhang III auf den 2. Dezember 2027 und nach Anhang I auf den 2. August 2028. Art. 50 (Transparenz) gilt unverändert seit dem 2. August 2026; die Kennzeichnungspflicht für synthetische Inhalte trifft den Anbieter, für vor dem 2. August 2026 in Verkehr gebrachte Systeme mit Übergangsfrist bis 2. Dezember 2026. Ab demselben Tag gelten neue Verbote in Art. 5 zu intimen Deepfakes und Missbrauchsmaterial. Art. 4 wurde neu gefasst: Anbieter und Betreiber „ergreifen Maßnahmen, um die Entwicklung der KI-Kompetenz ihres Personals und anderer Personen zu unterstützen“, ohne „für irgendeine Person ein bestimmtes Niveau an KI-Kompetenz zu garantieren“. Nach der FAQ der Kommission bleibt das eine Pflicht, deren Verletzung die nationalen Behörden nach nationalem Recht ahnden können. Art. 26 (Betreiberpflichten bei Hochrisiko) ist unverändert.

Einschätzung: Ein allgemeiner Büroassistent ist kein Hochrisiko-System. Das kann sich ändern, wenn Agenten in Bereichen eingesetzt werden, die Anhang III nennt, etwa bei Entscheidungen über Beschäftigungsverhältnisse oder bei der Kreditwürdigkeitsprüfung natürlicher Personen.

In Deutschland ist am 29. Juli 2026 das Gesetz zur Durchführung der KI-Verordnung in Kraft getreten (BGBl. 2026 I Nr. 223). Nach dem darin enthaltenen KI-Marktüberwachungs- und Innovationsförderungs-Gesetz (KI-MIG) ist die BaFin Marktüberwachungsbehörde für KI-Systeme, die in direktem Zusammenhang mit einer regulierten Finanztätigkeit stehen. Für übrige Anwendungen, etwa im Personalbereich von Finanzunternehmen, ist die Bundesnetzagentur zuständig. **Einschätzung:** Copilot als Büroassistent fällt eher in die Zuständigkeit der Bundesnetzagentur, Agenten in Zahlungsprozessen eher in die der BaFin. Für Institute wichtig ist § 15 Abs. 2 KI-MIG: Wer als Betreiber eines Hochrisiko-Systems nach Anhang III Nr. 1, 3, 4 oder 5 einer betroffenen Person die Erläuterung nach Art. 86 KI-VO verweigert, handelt ordnungswidrig, mit Geldbuße bis zu 50.000 Euro. Nr. 5 erfasst unter anderem die Kreditwürdigkeitsprüfung natürlicher Personen.

Im Finanzsektor ist Schulung doppelt Pflicht

Unabhängig davon, wie die Kompetenzpflicht der KI-Verordnung künftig formuliert ist: DORA verlangt in Art. 5 Abs. 4, dass das Leitungsorgan sein Wissen über IKT-Risiken aktuell hält, und in Art. 13 Abs. 6 Sensibilisierungsprogramme und Schulungen zur digitalen operationalen Resilienz für alle Beschäftigten. Die BaFin-Orientierungshilfe verknüpft die KI-Kompetenz der Mitarbeitenden ausdrücklich mit Art. 13 Abs. 6. Hinzu kommt der Schulungsauftrag des DSB nach Art. 39 Abs. 1 lit. b DSGVO. Wer Copilot ohne nachweisbare Schulung ausrollt, hat in einem Zahlungsinstitut damit gleich drei Lücken.

14

Agenten und Copilot Studio: eigene Prüfspur

DSGVO

DORA

Tenant-Einstellung

Mit Agenten verschiebt sich die Frage von „Was darf Copilot finden?“ zu „Was darf Copilot tun?“. Agenten verbinden sich mit Wissensquellen und Werkzeugen, sie können Connectoren, HTTP-Aufrufe und MCP-Server nutzen und mit eigener Identität autonom handeln. Jeder Agent ist damit ein eigener Verarbeitungsvorgang und, in DORA-Logik, ein IKT-Asset für das Inventar nach Art. 8.

Thema	Was Microsoft dokumentiert
Datenresidenz	Copilot Studio liegt in der EU Data Boundary, wenn die Rechnungsadresse in EU/EFTA liegt und alle Umgebungen in EU-Regionen angelegt sind. Im Power Platform Admin Center gibt es eigene Schalter für Datenbewegung über Regionen, Bing-Suche und Flex Routing.
Data Policies	Im Power Platform Admin Center lassen sich unauthentifizierte Agenten, Wissensquellen, Connectoren einschließlich MCP, HTTP-Anfragen und einzelne Kanäle sperren.
Gesprächsprotokolle	Speicherung in Dataverse, standardmäßig 30 Tage; Speicherung und Einsicht je Umgebung abschaltbar.
Identität und Verwaltung	Microsoft Entra Agent ID mit eigener Agent-Identität, Conditional Access und verpflichtendem Sponsor, laut Dokumentation teilweise noch in Vorschau; Microsoft Agent 365 seit Mai 2026 allgemein verfügbar als Verwaltungsebene mit Agent-Register.
SharePoint-Agenten	Antworten richten sich nach den Berechtigungen des jeweiligen Nutzers; Restricted Content Discovery schaltet Agenten auf einer Site ab.

■ WAS DER DSB EINFORDERN SOLLTE

Einen Freigabeprozess, bevor ein Agent produktiv geht, mit einem Steckbrief: Zweck, Datenquellen, Aktionen und Schreibrechte, Identität, verantwortliche Person, Modellanbieter, Protokollierung und Löschfrist. Autonome Agenten mit Schreibzugriff auf Kunden- oder Zahlungsdaten brauchen eine Ergänzung der DSFA und die Einstufungsprüfung nach K4. Entscheidungen mit Rechtswirkung gegenüber Kunden bleiben beim Menschen (Art. 22 DSGVO). Und jeder freigegebene Agent wird im Inventar geführt, damit IKT-Risikomanagement und Datenschutz auf dieselbe Liste schauen.

TEIL D

Handeln

15 Änderungen im Blick behalten

Tenant-Einstellung

DORA

Eine Copilot-DSFA ist nach drei Monaten veraltet, wenn niemand die Änderungen verfolgt. Allein 2026 hat sich an Stellen etwas bewegt, die für Datenschutz und Aufsicht relevant sind:

Datum	Änderung
25.03.2026	Stichtag: Für danach angelegte EU-Tenants sind Flex Routing und Anthropic in Word, Excel und PowerPoint standardmäßig aktiv
03.04.2026	neue Einstellung „Copilot in Microsoft 365 apps with Anthropic models“ für EU/EFTA/UK
01.05.2026	bisherige Einstellung für Anthropic als unabhängigen Verarbeiter abgeschaltet; Anthropic-Modelle laufen seitdem als Unterauftragsverarbeiter (Ausnahme: Modelle mit Datenaufbewahrung); Microsoft Agent 365 allgemein verfügbar
22.05.2026	neue Fassung des Microsoft Products and Services DPA
30.06.2026	neue MaRisk (Rundschreiben 06/2026) für Kredit- und Finanzdienstleistungsinstitute
23.06. / 24.07.2026	OpenAI in der Unterauftragsverarbeiterliste; ab 24.07. für alle Nutzer berechtigter Kunden aktiv
27.07. / 29.07.2026	Digital-Omnibus-Verordnung zur KI (VO (EU) 2026/1744) in Kraft; KI-MIG in Kraft
31.07.2026	Restricted SharePoint Search kann nicht mehr neu aktiviert werden
02.08.2026	Art. 50 KI-VO (Transparenz) anwendbar
14.09. / 14.12.2026	Einstellung „Store Microsoft 365 customer data in-country“ für DE-Tenants; ab 14.12. wirksam, bei „Off“ Speicherung regional in der EU Data Boundary möglich
02.12.2026	Neue Verbote in Art. 5 KI-VO; Ende der Übergangsfrist für Anbieter zur Kennzeichnung synthetischer Inhalte
02.12.2027 / 02.08.2028	Hochrisiko-Pflichten nach Anhang III bzw. Anhang I der KI-VO anwendbar
laufend	Umbenennung in „Microsoft Copilot“ und „Microsoft Copilot Chat“; neue Lizenzbezeichnungen

Der DSB braucht deshalb einen festen Kanal: Message-Center-Meldungen zu Copilot, Purview und Datenresidenz werden an Datenschutz und Informationssicherheit weitergeleitet, die Unterauftragsverarbeiterliste ist abonniert, und mindestens quartalsweise wird geprüft, ob DSFA, VVT, Informationsregister und Datenschutzhinweise angepasst werden müssen. Neue Funktionen gehen vor der Freischaltung durch eine kurze Prüfung, bevor sie in der Fläche ankommen.

16 Zuständigkeiten und Fragen, die der DSB stellen sollte

DSGVO

DORA

ZAG · BaFin

Die Copilot-Einführung im Zahlungsinstitut scheitert selten an einer einzelnen Norm, sondern an Schnittstellen. Eine kurze Zuordnung schafft Klarheit, bevor die erste Lizenz zugewiesen wird.

Aufgabe	verantwortlich	mitwirkend	Rolle des DSB
KI-Strategie und Nutzungsrichtlinie	Leitungsorgan	IKT-Risikomanagement, Compliance	berät, prüft Zwecke und Rechtsgrundlagen
Einstufung, Informationsregister, Anzeigen	Auslagerungs- und Drittparteienmanagement	IKT-Risikomanagement	liefert Datenflüsse und Unterauftragsverarbeiter
Tenant-Einstellungen (K7, K8, K9)	IT / M365-Administration	Informationssicherheit	fordert dokumentierte Entscheidungen ein
DSFA	Verantwortlicher (Fachbereich, IT)	ISB, IKT-Risikomanagement, Betriebsrat	berät nach Art. 35 Abs. 2 DSGVO
Ausschluss von GwG-Bereichen	Geldwäschebeauftragter	IT	prüft Wirksamkeit mit
Vorfallprozess	IKT-Risikomanagement	ISB, Kommunikation	Pflichtbeteiligter bei Personenbezug
Schulung	Personal / L&D	IKT-Risikomanagement	bringt Datenschutzzinhalte ein

Beispielhafte Zuordnung; sie ersetzt nicht die Organisationsrichtlinien des Instituts.

AN IT UND ADMINISTRATION

- Wann wurde unser Tenant angelegt, und wie stehen Flex Routing, beide Anthropic-Schalter, OpenAI, die Web-Suche und „Store Microsoft 365 customer data in-country“? Wer hat das wann entschieden?
- Welche Sites enthalten KYC-, GwG-, Betrugs- und Personaldaten, und wie sind sie von Copilot ausgenommen?
- Welche Aufbewahrungs- und Audit-Richtlinien gelten für Copilot, und wer darf Prompt-Inhalte einsehen?

AN IKT-RISIKOMANAGEMENT UND AUSLAGERUNGSMANAGEMENT

- Wie ist Copilot eingestuft, und auf welchen Nutzungsszenarien beruht die Einstufung?
- Ist der Vertrag mit Microsoft im Informationsregister vollständig, einschließlich der KI-Unterauftragsverarbeiter?
- Liegt das DORA-Addendum vor, und wer bearbeitet Änderungsmitteilungen von Microsoft?

AN GESCHÄFTSLEITUNG UND FACHBEREICHE

- Gibt es eine vom Leitungsorgan genehmigte KI-Strategie oder Nutzungsrichtlinie?
- Welche Anwendungsfälle mit Kundendaten sind geplant, und welche sind ausdrücklich ausgeschlossen?
- Wie wird die Schulung von Leitungsorgan und Beschäftigten nachgewiesen?

NÄCHSTE ETAPPE

Schulen Sie Ihr Institut auf Copilot unter Aufsicht

Die beste Konfiguration nützt wenig, wenn Beschäftigte Kundendaten in die falsche Funktion kopieren, Verdachtsfälle in offenen Teams-Kanälen besprechen oder Copilot-Ergebnisse ungeprüft an Kunden weitergeben. Genau hier setzen die Trainings der Copilotenschule an: Wir schulen Ihre Beschäftigten praxisnah auf **Grounding, sichere Freigaben und den regelkonformen Umgang mit Kunden- und Zahlungsdaten** – abgestimmt auf Ihre Microsoft-365-Umgebung, Ihre Nutzungsrichtlinie und die Anforderungen an Schulungsnachweise aus DORA und KI-Verordnung.

Vom Compliance-Workshop für Datenschutz, Informationssicherheit und Betriebsrat über die Sensibilisierung des Leitungsorgans bis zur breitenwirksamen Anwenderschulung: Wir befähigen Wissensarbeiter, Teams und Organisationen, Copilot produktiv, sicher und wertschöpfend einzusetzen – ohne Bauchladen, mit Fokus auf das, was in Ihrem regulierten Umfeld compliant und wertschöpfend ist.

15-Minuten-Erstgespräch buchen[outlook.office.com](mailto:info@copilotenschule.de) · direkter Terminkalender**Kontaktformular: Schulung für Ihr Institut anfragen**copilotenschule.de/#contact**Weitere Details: Grounding-Fachartikel lesen**copilotenschule.de/wissen/welche-daten-sieht-microsoft-365-copilot**E-MAIL**info@copilotenschule.de**TELEFON**

+49 221 950 187 74

TEAMS-CHAT

Direkt im Teams-Chat schreiben

WEBcopilotenschule.de · Köln (DACH & Remote)

Herausgeber: copilotenschule.de – eine Marke der Yellow-Boat Consulting (gegründet 2011), Köln. Verantwortlich: Martin Lang. Kontakt: info@copilotenschule.de · +49 221 950 187 74. Vollständiges Impressum: copilotenschule.de/impressum · Datenschutz: copilotenschule.de/datenschutz.



BELEGE

Quellen & Rechtsgrundlagen

Alle Quellen abgerufen im Oktober 2026. EU-Rechtsakte in der Fassung des Amtsblatts.

EU-Recht und europäische Aufsicht

- VO (EU) 2022/2554 (DORA), insb. Art. 2, 3, 5–19, 23, 28–30, 64 — eur-lex.europa.eu/eli/reg/2022/2554/oj
- DelVO (EU) 2024/1773 (Leitlinie IKT-Dienstleistungen für kritische oder wichtige Funktionen) — eur-lex.europa.eu/eli/reg_del/2024/1773/oj
- DelVO (EU) 2024/1774 (RTS IKT-Risikomanagementrahmen) — eur-lex.europa.eu/eli/reg_del/2024/1774/oj
- DelVO (EU) 2025/532 (RTS Unterauftragsvergabe) — eur-lex.europa.eu/eli/reg_del/2025/532/oj
- DurchfVO (EU) 2024/2956 (ITS Informationsregister) — eur-lex.europa.eu/eli/reg_impl/2024/2956/oj
- DelVO (EU) 2024/1772 (Klassifizierung von Vorfällen) und 2025/301 (Meldefristen); DurchfVO (EU) 2025/302 (Meldeformulare) — eur-lex.europa.eu/eli/reg_del/2024/1772/oj, .../[reg_del/2025/301/oj](https://eur-lex.europa.eu/eli/reg_del/2025/301/oj)
- Richtlinie (EU) 2015/2366 (PSD2), Art. 32, 94; Änderung durch Richtlinie (EU) 2022/2556 — eur-lex.europa.eu/eli/dir/2015/2366/oj
- VO (EU) 2016/679 (DSGVO), Art. 5, 6, 9, 22, 28, 33–35, 39, 88 — eur-lex.europa.eu/eli/reg/2016/679/oj
- VO (EU) 2024/1689 (KI-Verordnung) — eur-lex.europa.eu/eli/reg/2024/1689/oj; VO (EU) 2026/1744 (Digital-Omnibus-Verordnung zur KI, ABl. L 24.07.2026) — eur-lex.europa.eu/eli/reg/2026/1744/oj; Europäische Kommission: „AI Omnibus enters into force“ — digital-strategy.ec.europa.eu/en/news/ai-omnibus-enters-force; FAQ KI-Kompetenz — digital-strategy.ec.europa.eu/en/faqs/ai-literacy-questions-answers
- ESAs: Liste der benannten kritischen IKT-Drittdienstleister (18.11.2025) — esma.europa.eu/sites/default/files/2025-11/List_of_designated_CTPPs.pdf
- EDPB: Leitlinien 06/2020 zum Zusammenspiel von PSD2 und DSGVO — [edpb.europa.eu \(Guidelines 06/2020\)](https://edpb.europa.eu/Guidelines_06/2020); Stellungnahme 28/2024 zu KI-Modellen
- EuGH, Urteile C-34/21 vom 30.03.2023 und C-65/23 vom 19.12.2024 — curia.europa.eu
- EBA: Leitlinien zum Drittparteienrisiko für Nicht-IKT-Dienstleistungen (EBA/GL/2026/09, 18.09.2026) — eba.europa.eu

BaFin und nationales Recht

- BaFin: Orientierungshilfe zu IKT-Risiken beim Einsatz von KI in Finanzunternehmen (18.12.2025) — bafin.de/.../dl_Anlaege_orientierungshilfe_IKT_Risiken_bei_KI.pdf
- BaFin: „DORA kommt: Änderungen bei den aufsichtlichen Anforderungen an die IT“ (01/2025) und Aufhebung der ZAIT — bafin.de/.../meldung_2025_01_09_DORA.html
- BaFin: Rundschreiben 07/2024 (BA) – ZAG-MaRisk (27.05.2024) — bafin.de/.../rs_Rundschreiben_07_24.html; Rundschreiben 06/2026 (BA) – MaRisk
- BaFin: Aufsichtsmitteilung zu Auslagerungen an Cloud-Anbieter (01.02.2024) — bafin.de/.../meldung_2024_02_01_Cloud_Anbieter.html
- BaFin: Register- und Anzeigepflichten, FAQ DORA-Informationsregister — bafin.de/.../register-anzeigepflichten_node.html
- BaFin: KI-Marktüberwachung, Pressemitteilung vom 29.07.2026 — bafin.de/.../pm_2026_07_29_ki_verordnung.html; KI-MIG, BGBl. 2026 I Nr. 223, §§ 2, 15 — gesetze-im-internet.de/ki-mig
- BSI-Gesetz (BSiG) vom 02.12.2025, BGBl. 2025 I Nr. 301, § 28 Abs. 6 — gesetze-im-internet.de/bsig_2025
- ZAG §§ 26, 27, 59 — gesetze-im-internet.de/zag_2018; GwG §§ 8, 43, 47 — gesetze-im-internet.de/gwg_2017; BetrVG § 87

- Wissenschaftlicher Dienst des Bundestags: Bankgeheimnis (WD 51/05, 2005) — bundestag.de

Datenschutzaufsicht

- DSK: Orientierungshilfe „Künstliche Intelligenz und Datenschutz“ (06.05.2024) — datenschutzkonferenz-online.de/media/oh/20240506_DSK_Orientierungshilfe_KI_und_Datenschutz.pdf
- DSK: Orientierungshilfe zu TOM bei Entwicklung und Betrieb von KI-Systemen (06/2025) — datenschutzkonferenz-online.de/media/oh/DSK-OH_KI-Systeme.pdf
- DSK: Orientierungshilfe zu datenschutzrechtlichen Besonderheiten generativer KI-Systeme mit RAG-Methode, Version 1.0 (10/2025) — datenschutzkonferenz-online.de/media/oh/DSK_OH_RAG.pdf
- DSK: Festlegung zu Microsoft 365 (24.11.2022); DSFA-Muss-Liste (Version 1.1) — datenschutzkonferenz-online.de
- HBdi: Bericht zu Microsoft 365 (15.11.2025) — datenschutz.hessen.de/.../hbdi_bericht_m365_2025_11_15.pdf

Microsoft (Microsoft Learn, Service Trust Portal)

- Data, privacy, and security for Microsoft 365 Copilot — learn.microsoft.com/copilot/microsoft-365/microsoft-365-copilot-privacy
- Enterprise data protection; Manage public web access — .../copilot/microsoft-365/enterprise-data-protection, .../[manage-public-web-access](https://.../manage-public-web-access)
- Flex routing (EU and EFTA) — learn.microsoft.com/microsoft-365/copilot/copilot-flex-routing
- Anthropic models in Microsoft Online Services; Copilot in Microsoft 365 apps with Anthropic models; OpenAI as a subprocessor — .../copilot/microsoft-365/connect-to-ai-subprocessor, .../[copilot-anthropic-apps](https://.../copilot-anthropic-apps), .../[openai-subprocessor](https://.../openai-subprocessor)
- EU Data Boundary: ongoing partial transfers — learn.microsoft.com/privacy/eudb/eu-data-boundary-ongoing-partial-transfers
- Retention policies for Copilot; Audit Copilot interactions; Audit log retention policies — learn.microsoft.com/purview/retention-policies-copilot, .../[audit-copilot](https://.../audit-copilot), .../[audit-log-retention-policies](https://.../audit-log-retention-policies)
- DLP for Microsoft 365 Copilot; Considerations for Purview and Copilot — learn.microsoft.com/purview/dlp-microsoft365-copilot-location-learn-about
- SharePoint Advanced Management with Copilot license; Restricted SharePoint Search — learn.microsoft.com/sharepoint/...
- Copilot Studio: data residency, data policies, transcript controls; Power Platform geographical availability — learn.microsoft.com/microsoft-copilot-studio/...
- Microsoft Agent 365; Microsoft Entra Agent ID — learn.microsoft.com/microsoft-agent-365/overview
- DORA contract mapping — learn.microsoft.com/compliance/dora/dora-contract-mapping
- Microsoft Products and Services DPA (Fassung 22.05.2026) — microsoft.com/licensing/docs/view/Microsoft-Products-and-Services-Data-Protection-Addendum-DPA
- Build your own M365 Copilot DPIA (06/2025); Copilot & Copilot Chat Risk Assessment Quickstart — wwps.microsoft.com, servicetrust.microsoft.com

Begleitende Leitfäden der Copilotenschule

- „Grounding sicher gestalten“ (Admin), „Grounding mitbestimmen“ (Betriebsrat), „Richtig einführen“ (Management) — copilotenschule.de/guidelines